

Scenario 3 output 2 chatgpt

Threat 1 — Account Recovery Authorization Bypass

- **Threat ID:** T3-01
- **Threat name:** Account Recovery Authorization Bypass
- **STRIDE category:** Elevation of Privilege
- **Affected component/data flow:** EE1 → P1 → P2; P2 → DS1/DS2
- **Attack scenario:** An attacker submits malicious or manipulated recovery information through P1. If P2's identity-verification logic incorrectly accepts the information, the attacker can obtain recovery authorization for another user's account.
- **Impact:** Full account takeover, unauthorized access to account information, and potential subsequent profile modification.
- **Severity:** Critical
- **Likelihood:** Medium
- **Mitigation:** Enforce strong identity verification in P2; use multiple independent verification factors; apply anti-automation and rate-limiting controls; ensure recovery decisions are made exclusively by P2; fail closed when verification is ambiguous; log and monitor recovery attempts.
- **OWASP LLM Top 10 mapping:** LLM01 – Prompt Injection if LLM-generated guidance influences the user's recovery submission; LLM06 – Excessive Agency if AI output is incorrectly treated as an authorization signal.

Threat 2 — Malicious Recovery Information Manipulation

- **Threat ID:** T3-02
- **Threat name:** Recovery Verification Data Manipulation
- **STRIDE category:** Tampering
- **Affected component/data flow:** EE1 → P1 → P2 → DS1
- **Attack scenario:** An attacker provides fabricated, altered, or carefully constructed recovery information intended to satisfy P2's identity-verification requirements.
- **Impact:** Unauthorized recovery authorization and possible account takeover.
- **Severity:** Critical
- **Likelihood:** High
- **Mitigation:** Treat all recovery information as untrusted; perform server-side validation in P2; use strong verification mechanisms; never trust client-side validation; enforce attempt limits; prevent partial or weak verification from being interpreted as successful identity verification.
- **OWASP LLM Top 10 mapping:** LLM01 – Prompt Injection where malicious content is passed into AI-assisted recovery guidance.

Threat 3 — Recovery Token Replay

- **Threat ID:** T3-03

- **Threat name:** Recovery Token Replay
- **STRIDE category:** Elevation of Privilege
- **Affected component/data flow:** P2 ↔ DS2; recovery token validation
- **Attack scenario:** An attacker obtains a previously valid recovery token and attempts to reuse it after it has already been used or after the intended recovery operation has completed.
- **Impact:** Repeated unauthorized account recovery and potentially repeated account takeover.
- **Severity:** Critical
- **Likelihood:** Medium
- **Mitigation:** P2 must validate token status against DS2; enforce expiration; atomically mark tokens as consumed/invalidation state; ensure each token can be used only once; reject expired or consumed tokens.
- **OWASP LLM Top 10 mapping:** No direct LLM Top 10 category. This is primarily a recovery-token lifecycle security issue.

Threat 4 — Recovery Token Leakage

- **Threat ID:** T3-04
- **Threat name:** Exposure of Recovery Tokens
- **STRIDE category:** Information Disclosure
- **Affected component/data flow:** P2 ↔ DS2; P1 ↔ P2; P4/P5 → EE2
- **Attack scenario:** Recovery tokens are accidentally exposed through application responses, AI context, prompts, logs, or other data passed through the system. Although the architecture explicitly prevents tokens from being sent to EE2, an implementation could violate this boundary.
- **Impact:** An attacker possessing a valid token may bypass normal recovery verification and take over an account.
- **Severity:** Critical
- **Likelihood:** Medium
- **Mitigation:** Keep recovery tokens strictly within P2/DS2-controlled flows; never include tokens in P4 prompts or P5-approved context; enforce data filtering before external LLM transmission; prevent tokens from appearing in user-facing AI responses; validate outbound data against an explicit allowlist.
- **OWASP LLM Top 10 mapping:** LLM02 – Sensitive Information Disclosure; LLM06 – Excessive Agency.

Threat 5 — Identity Verification Bypass Through AI Guidance

- **Threat ID:** T3-05
- **Threat name:** AI-Assisted Identity Verification Manipulation
- **STRIDE category:** Elevation of Privilege
- **Affected component/data flow:** EE1 → P4 → P5 → EE2; P4 → EE1
- **Attack scenario:** An attacker asks P4 for advice on how to satisfy recovery verification requirements. The assistant reveals excessive information about verification procedures, allowing the attacker to optimize fraudulent recovery information.
- **Impact:** Increased probability of successful identity-verification fraud and account takeover.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** P4 should provide only general recovery guidance; avoid revealing internal verification rules, thresholds, or security-sensitive decision logic; do not expose information

that helps an attacker determine which verification responses will be accepted; maintain strict separation between assistance and authorization.

- **OWASP LLM Top 10 mapping:** LLM02 – Sensitive Information Disclosure; LLM01 – Prompt Injection.

Threat 6 — Prompt Injection Through User Recovery Information

- **Threat ID:** T3-06
- **Threat name:** Recovery-Input Prompt Injection
- **STRIDE category:** Tampering
- **Affected component/data flow:** EE1 → P1 → P4/P5 → EE2
- **Attack scenario:** An attacker submits recovery information containing instructions such as attempts to override system instructions, reveal hidden context, or manipulate the assistant's behavior. The malicious content reaches P4/P5 and influences LLM processing.
- **Impact:** Manipulated AI responses, disclosure of sensitive information, or misleading recovery guidance. Under the stated architecture, it should **not** directly authorize recovery because P4 has no recovery authority.
- **Severity:** High
- **Likelihood:** High
- **Mitigation:** Treat all user-provided content as untrusted; isolate user content from system instructions; use strong prompt separation; sanitize inputs before constructing prompts; minimize context supplied to the LLM; never allow LLM output to become an authorization input to P2.
- **OWASP LLM Top 10 mapping:** LLM01 – Prompt Injection.

Threat 7 — Indirect Prompt Injection Through Approved Context

- **Threat ID:** T3-07
- **Threat name:** Malicious Content in LLM Context
- **STRIDE category:** Tampering
- **Affected component/data flow:** DS1 → P5 → EE2 → P4
- **Attack scenario:** Malicious text stored in user profile information or other approved context is included in a sanitized prompt. The external LLM interprets that text as instructions rather than data.
- **Impact:** Manipulated AI responses, misleading recovery advice, or attempts to expose information contained in the LLM context.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Treat database content as untrusted when constructing prompts; clearly delimit data from instructions; minimize context; sanitize content without relying solely on keyword filtering; constrain expected output; validate returned content before displaying it.
- **OWASP LLM Top 10 mapping:** LLM01 – Prompt Injection.

Threat 8 — Sensitive Account Information Disclosure

- **Threat ID:** T3-08

- **Threat name:** Unauthorized Disclosure of Account Information
- **STRIDE category:** Information Disclosure
- **Affected component/data flow:** DS1 → P5 → EE2; P4 → EE1
- **Attack scenario:** Sensitive profile or account information is accidentally included in approved LLM context, or P4 reveals information in response to an attacker's questions.
- **Impact:** Exposure of private account information and increased ability to conduct identity fraud or social engineering.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Apply strict data minimization before P5 sends context to EE2; enforce the stated rule that private account data is never sent externally; use explicit allowlists for approved context; prevent P4 from disclosing information unless the information is appropriate for the requesting user.
- **OWASP LLM Top 10 mapping:** LLM02 – Sensitive Information Disclosure.

Threat 9 — Insecure LLM Output Handling

- **Threat ID:** T3-09
- **Threat name:** Malicious or Misleading LLM Output
- **STRIDE category:** Spoofing / Tampering
- **Affected component/data flow:** EE2 → P5 → P4 → P1 → EE1
- **Attack scenario:** The external LLM returns manipulated, incorrect, or malicious content. P4 or P1 displays the response without adequate validation or contextual controls.
- **Impact:** Users may follow unsafe recovery instructions, disclose secrets, or perform actions that weaken account security.
- **Severity:** High
- **Likelihood:** High
- **Mitigation:** Treat all external LLM output as untrusted; validate output before presentation; constrain response formats; do not render executable or active content; clearly distinguish guidance from authoritative recovery decisions; never use LLM output as an authorization signal.
- **OWASP LLM Top 10 mapping:** LLM05 – Improper Output Handling.

Threat 10 — Excessive AI Agency

- **Threat ID:** T3-10
- **Threat name:** Unauthorized Expansion of AI Authority
- **STRIDE category:** Elevation of Privilege
- **Affected component/data flow:** P4/P5 ↔ P2/P3
- **Attack scenario:** An implementation accidentally allows P4 or P5 output to influence P2's recovery authorization or P3's profile-update decision, despite the architecture explicitly restricting the AI to guidance.
- **Impact:** AI-mediated account takeover, unauthorized recovery, and unauthorized profile modification.
- **Severity:** Critical
- **Likelihood:** Low–Medium
- **Mitigation:** Maintain a hard architectural separation between P4/P5 and authorization functions; P2 must independently make every recovery decision; P3 must independently enforce authorization; never use LLM output as a Boolean authorization decision, identity-verification result, or token-validation result.

- **OWASP LLM Top 10 mapping: LLM06 – Excessive Agency.**

Threat 11 — Unauthorized Profile Modification

- **Threat ID:** T3-11
- **Threat name:** Profile Update Without Recovery Authorization
- **STRIDE category:** Elevation of Privilege
- **Affected component/data flow:** P1 → P3; P2 → P3; P3 → DS1
- **Attack scenario:** An attacker attempts to submit a profile update directly through P1 or manipulate recovery-related requests so that P3 performs an update without receiving valid authorization from P2.
- **Impact:** Unauthorized changes to account information, potential account takeover, and persistence of attacker-controlled information.
- **Severity:** Critical
- **Likelihood:** Medium
- **Mitigation:** P3 must independently verify that the required authorization originated from P2; never rely on client-side claims; enforce server-side authorization checks; reject profile updates without valid authorization; ensure authorization state cannot be modified by P4 or P5.
- **OWASP LLM Top 10 mapping: LLM06 – Excessive Agency** if AI output is incorrectly accepted as authorization.

Threat 12 — Profile Update Parameter Tampering

- **Threat ID:** T3-12
- **Threat name:** Malicious Profile Update Manipulation
- **STRIDE category:** Tampering
- **Affected component/data flow:** EE1 → P1 → P3 → DS1
- **Attack scenario:** An attacker manipulates profile-update parameters to modify fields they should not control or attempts to alter authorization-related account information.
- **Impact:** Account compromise, persistence, unauthorized changes to identity information, and potential future recovery abuse.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Perform strict server-side input validation in P3; use field-level authorization; permit only explicitly allowed profile fields to be modified; prevent modification of security-sensitive recovery information without appropriate authorization; validate all updates before writing to DS1.
- **OWASP LLM Top 10 mapping:** No direct LLM Top 10 category; **LLM06 – Excessive Agency** applies if LLM output is involved in determining update authority.

Threat 13 — Recovery Token Metadata Disclosure

- **Threat ID:** T3-13
- **Threat name:** Token Lifecycle Information Leakage
- **STRIDE category:** Information Disclosure
- **Affected component/data flow:** DS2 → P2 → P1/P4

- **Attack scenario:** Information about token expiration, consumption state, or token existence is exposed through application responses or AI-generated guidance. An attacker can use this information to improve token attacks.
- **Impact:** Facilitates token guessing, replay attempts, targeted recovery attacks, and account enumeration.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Minimize information returned about token state; do not expose token metadata to P4 or EE2; provide generic failure responses where appropriate; keep token lifecycle information inside P2/DS2.
- **OWASP LLM Top 10 mapping:** LLM02 – Sensitive Information Disclosure when token metadata reaches the LLM.

Threat 14 — Account Enumeration Through Recovery

- **Threat ID:** T3-14
- **Threat name:** Recovery-Based Account Enumeration
- **STRIDE category:** Information Disclosure
- **Affected component/data flow:** EE1 → P1 → P2 → P1
- **Attack scenario:** An attacker submits recovery requests for different identities and compares responses to determine whether an account exists or whether particular recovery information is valid.
- **Impact:** Disclosure of account existence and increased effectiveness of targeted phishing, credential attacks, and identity-verification attacks.
- **Severity:** Medium
- **Likelihood:** High
- **Mitigation:** Use consistent responses and timing for account-existence and recovery failures where practical; rate-limit recovery requests; monitor repeated enumeration patterns; do not expose internal verification details through P1 or P4.
- **OWASP LLM Top 10 mapping:** LLM02 – Sensitive Information Disclosure if the AI assistant reveals account-existence information.

Threat 15 — LLM Provider Trust-Boundary Risk

- **Threat ID:** T3-15
- **Threat name:** External LLM Provider Compromise or Misuse
- **STRIDE category:** Information Disclosure
- **Affected component/data flow:** P5 → EE2 → P5
- **Attack scenario:** The external LLM provider is outside application security control. A compromised provider, unintended retention mechanism, provider-side processing issue, or malicious external behavior could expose information transmitted by P5.
- **Impact:** Disclosure of prompts or approved context and potential exposure of account-related information.
- **Severity:** High
- **Likelihood:** Low–Medium
- **Mitigation:** Send only the minimum sanitized information required; enforce the explicit prohibition on recovery tokens, identity-verification secrets, and private account data; use strict outbound data filtering in P5; maintain an allowlist of permitted context; treat EE2 as untrusted.

- **OWASP LLM Top 10 mapping:** LLM02 – Sensitive Information Disclosure; LLM03 – Supply Chain.

Threat 16 — Malicious External LLM Response

- **Threat ID:** T3-16
- **Threat name:** External LLM Response Manipulation
- **STRIDE category:** Spoofing / Tampering
- **Affected component/data flow:** EE2 → P5 → P4
- **Attack scenario:** EE2 returns a response designed to manipulate the application or user, including false statements that imply recovery authorization, token validity, or permission to modify a profile.
- **Impact:** User deception and potentially unsafe recovery actions. The impact is especially serious if downstream components incorrectly treat the response as authoritative.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Treat every EE2 response as untrusted; do not allow responses to trigger P2/P3 authorization; validate response content; constrain P4 to guidance; ensure security-critical decisions remain deterministic and independent of the LLM.
- **OWASP LLM Top 10 mapping:** LLM05 – Improper Output Handling; LLM06 – Excessive Agency.

Threat 17 — Prompt Leakage and System Instruction Disclosure

- **Threat ID:** T3-17
- **Threat name:** AI Instruction Disclosure
- **STRIDE category:** Information Disclosure
- **Affected component/data flow:** EE1 → P4/P5; P5 → EE2
- **Attack scenario:** An attacker uses prompt-injection techniques to persuade P4 to reveal internal instructions, sanitized context, security rules, or other information used to construct its prompts.
- **Impact:** Disclosure of security-relevant information that can help attackers construct more effective recovery attacks.
- **Severity:** Medium–High
- **Likelihood:** High
- **Mitigation:** Do not expose system prompts or internal security instructions; minimize sensitive context; isolate instructions from user data; implement prompt-injection defenses; maintain strict output filtering.
- **OWASP LLM Top 10 mapping:** LLM01 – Prompt Injection; LLM07 – System Prompt Leakage.

Threat 18 — Unbounded AI Resource Consumption

- **Threat ID:** T3-18
- **Threat name:** AI-Assisted Denial of Service
- **STRIDE category:** Denial of Service
- **Affected component/data flow:** EE1 → P1 → P4/P5 → EE2

- **Attack scenario:** An attacker submits excessive account-related questions or unusually large malicious inputs, causing repeated processing by P4/P5 and potentially consuming available LLM resources.
- **Impact:** Increased service cost, degraded availability, and reduced ability of legitimate users to obtain recovery guidance.
- **Severity:** Medium
- **Likelihood:** Medium–High
- **Mitigation:** Apply request rate limits; restrict input size; enforce quotas; limit unnecessary LLM calls; reject malformed or excessively large prompts; monitor abnormal AI usage patterns.
- **OWASP LLM Top 10 mapping:** LLM04 – Model Denial of Service.

Threat 19 — Recovery Workflow Confusion Through Hallucinated Guidance

- **Threat ID:** T3-19
- **Threat name:** Incorrect Recovery Guidance
- **STRIDE category:** Spoofing
- **Affected component/data flow:** EE2 → P5 → P4 → EE1
- **Attack scenario:** The external LLM generates incorrect recovery instructions, such as telling a legitimate user to provide information that should not be disclosed or incorrectly describing how recovery works.
- **Impact:** Users may expose sensitive information, fail recovery, or follow insecure procedures.
- **Severity:** Medium
- **Likelihood:** High
- **Mitigation:** Constrain P4 to approved recovery guidance; use authoritative application-provided information rather than relying on model-generated security procedures; validate critical guidance; explicitly warn users that AI responses do not authorize recovery.
- **OWASP LLM Top 10 mapping:** LLM09 – Misinformation; LLM05 – Improper Output Handling.

Threat 20 — Recovery-to-Profile Privilege Escalation

- **Threat ID:** T3-20
- **Threat name:** Recovery Authorization Used Beyond Its Intended Scope
- **STRIDE category:** Elevation of Privilege
- **Affected component/data flow:** P2 → P3 → DS1
- **Attack scenario:** An attacker obtains legitimate recovery authorization for a limited recovery operation and attempts to use that authorization to perform broader profile modifications than intended.
- **Impact:** Unauthorized modification of account information and potential persistent account takeover.
- **Severity:** Critical
- **Likelihood:** Medium
- **Mitigation:** Enforce least privilege between P2 and P3; define exactly what authorization permits; require P3 to validate authorization scope; prevent recovery authorization from automatically granting unrestricted profile-management privileges; log security-sensitive profile changes.

- **OWASP LLM Top 10 mapping: LLM06 – Excessive Agency** where AI-mediated workflows incorrectly broaden authorization.

Threat 21 — Unauthorized Disclosure Through AI Account Questions

- **Threat ID:** T3-21
- **Threat name:** Sensitive Information Exposure Through Support Queries
- **STRIDE category:** Information Disclosure
- **Affected component/data flow:** EE1 → P4 → P5 → EE2 / P4 → EE1
- **Attack scenario:** An attacker asks carefully constructed questions designed to make P4 reveal account-specific information, recovery status, profile information, or other sensitive details.
- **Impact:** Privacy breach and information that can be used for social engineering or account takeover.
- **Severity:** High
- **Likelihood:** Medium–High
- **Mitigation:** Restrict P4's access to account-specific information; expose only the minimum approved context; prevent disclosure of identity-verification information and recovery state; apply authorization checks outside the LLM before providing account-specific context.
- **OWASP LLM Top 10 mapping: LLM02 – Sensitive Information Disclosure; LLM01 – Prompt Injection.**

Threat 22 — Trust Confusion Between AI Guidance and Recovery Authority

- **Threat ID:** T3-22
- **Threat name:** AI Authority Impersonation
- **STRIDE category:** Spoofing
- **Affected component/data flow:** P4 → P1 → EE1
- **Attack scenario:** The AI produces language that appears to confirm that a user's identity has been verified, recovery has been approved, or a profile update is authorized, even though P4 has no such authority.
- **Impact:** Users may believe an account recovery or profile change is authorized when it is not. This can also create opportunities for social engineering.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Clearly distinguish AI guidance from authoritative P2 decisions; prevent P4 from generating authorization-status claims; display authoritative recovery status only from P2/P3; use explicit application-controlled status indicators rather than LLM-generated claims.
- **OWASP LLM Top 10 mapping: LLM06 – Excessive Agency; LLM09 – Misinformation.**

Threat 23 — Recovery Token Validation Logic Manipulation

- **Threat ID:** T3-23
- **Threat name:** Token Validation Bypass

- **STRIDE category:** Tampering / Elevation of Privilege
- **Affected component/data flow:** EE1 → P1 → P2 → DS2
- **Attack scenario:** An attacker manipulates token input or token-validation parameters in an attempt to make P2 accept an invalid, expired, consumed, or otherwise unauthorized token.
- **Impact:** Unauthorized recovery and account takeover.
- **Severity:** Critical
- **Likelihood:** Medium
- **Mitigation:** Validate tokens exclusively in P2; use cryptographically strong unpredictable tokens; enforce expiration and consumption state through DS2; perform exact server-side validation; reject malformed or ambiguous tokens; ensure validation cannot be overridden by P1, P3, P4, or P5.
- **OWASP LLM Top 10 mapping:** No direct LLM Top 10 mapping; this is a core authentication/recovery control.

Threat 24 — Compromise Through Chained Recovery and Profile Modification

- **Threat ID:** T3-24
- **Threat name:** Recovery-to-Persistence Attack
- **STRIDE category:** Elevation of Privilege
- **Affected component/data flow:** EE1 → P1 → P2 → P3 → DS1
- **Attack scenario:** An attacker successfully compromises the recovery process, receives valid recovery authorization, and immediately modifies profile information through P3 to establish persistent control over the account.
- **Impact:** Complete account takeover with persistence even after the original recovery event.
- **Severity:** Critical
- **Likelihood:** Medium
- **Mitigation:** Apply strict authorization boundaries between P2 and P3; require P3 to verify the specific authorization scope; protect security-sensitive profile fields with additional controls; invalidate obsolete recovery state after successful recovery; record and monitor sensitive profile modifications.
- **OWASP LLM Top 10 mapping:** LLM06 – Excessive Agency only where AI involvement incorrectly expands the recovery authority; otherwise this is primarily an application authorization threat.